

VOM FINDING ZUM FIX

Active Directory Security mit AI Agents und Model Context Protocol (MCP)

Protiviti GmbH · Michael Herpers · 2026

AGENDA

1	**Ausgangslage** Warum Active Directory und AI Agents zusammengehören – und wo das Risiko liegt	≈ 6 Min.
2	**Grundlagen** Agents, MCP, Microsoft Foundry und API Management verständlich erklärt	≈ 9 Min.
3	**Architektur und Sicherheit** Zwei getrennte Pfade, Least Privilege, Human Approval	≈ 11 Min.
4	**Live-Demo** Vom Finding zum Fix – Assessment, Freigabe, Remediation, Verifikation	≈ 15 Min.
5	**Einordnung** Governance-Checkliste, Chancen und Grenzen, Roadmap, Takeaways	≈ 8 Min.

WARUM IST DAS RELEVANT?

Klassisches Active Directory trifft auf moderne AI Agents

Active Directory

Seit über 25 Jahren im Einsatz

Zentraler Identitätsdienst in fast jedem Unternehmen – hochkritisch

Kompromittierung bedeutet Kontrolle über die gesamte Domäne

Security-Reviews sind manuell, punktuell und aufwendig



AI Agents

Verstehen Ziele in natürlicher Sprache

Planen selbstständig und nutzen Werkzeuge statt nur zu antworten

Korrelieren Ergebnisse aus mehreren Quellen und schlagen Maßnahmen vor

Brauchen dafür Zugang zu Systemen – genau hier entsteht das Risiko

Die Frage ist nicht ob, sondern wie: Wie viel darf ein Agent in meinem Active Directory tun – und wer entscheidet das?

ACTIVE DIRECTORY UNTER DRUCK

Typische Schwachstellen, die ein Assessment heute findet

Privilegierte Konten

Zu viele Mitglieder in Domain Admins & Co. – oft historisch gewachsen

Passwörter ohne Ablauf

„Password never expires“ auf Service- und Admin-Accounts

Stale Accounts

Konten ohne Anmeldung seit Monaten – aber mit aktiven Rechten

Service Accounts

Hohe Rechte, selten rotiert, häufig unbekannter Eigentümer

Fehlende Transparenz

Prüfungen sind manuell, punktuell und schwer wiederholbar

Lange Reaktionszeit

Vom Finding bis zur Umsetzung vergehen oft Wochen

Wer Active Directory kontrolliert, kontrolliert die Identitäten – und damit das Unternehmen.

Die gute Nachricht: Diese Findings sind gut maschinell erkennbar – strukturierte Daten, klare Regeln, wiederholbare Abfragen. Genau hier setzt der AI Agent an.

DIE BEGRIFFE DES TAGES

Acht Bausteine – kurz erklärt, bevor es technisch wird

LLM

Sprachmodell, das Text versteht und erzeugt – das „Gehirn“ des Agenten

AI Agent

LLM plus Ziel, Instruktionen und Werkzeuge – kann planen und handeln

MCP

Model Context Protocol: offener Standard, über den Agents Tools nutzen

Tool

Eine definierte Funktion mit klarer Schnittstelle, z. B. get_user

Microsoft Foundry

Microsofts Plattform zum Bauen, Betreiben und Absichern von Agents

Azure API Management

Zentrales Gateway: Authentifizierung, Policies, Logging für alle Aufrufe

LDAPS

Verschlüsselter Zugriff auf Active Directory über TCP 636

Human Approval

Ein Mensch gibt eine Aktion frei, bevor sie ausgeführt wird

Merksatz: Das LLM denkt, der Agent plant, MCP verbindet, die Plattform kontrolliert – und der Mensch entscheidet.

VON CHATBOTS ZU AGENTS

Der Unterschied zwischen Antworten geben und Aktionen durchführen

Chatbot

Antwortet aus dem Training



Kein Systemzugriff · keine Werkzeuge · keine Verifikation – das Ergebnis ist Text

AI Agent

Plant, handelt, prüft



Nutzt definierte Werkzeuge · liest echte Daten · handelt innerhalb definierter Grenzen

Mehr als ein Chatbot: Der Mehrwert entsteht, wenn der Agent mehrere Werkzeuge orchestriert und die Ergebnisse korreliert.

ANATOMIE EINES AI AGENTEN

Fünf Bausteine – und warum Governance von Anfang an dazugehört

1 Modell

Das LLM – versteht die Aufgabe und formuliert Ergebnisse

2 Instruktionen

Rolle, Ziele und Regeln – z. B. „nichts ohne Freigabe ändern“

3 Tools (MCP)

Die Hände des Agenten – nur was als Tool existiert, kann er tun

4 Kontext

Tool-Antworten und Verlauf – daraus entsteht die Korrelation

5 Governance

Berechtigungen, Approval, Logging – was tatsächlich passieren darf

Der Agent arbeitet in einer Schleife

Ziel verstehen → Tool wählen → Tool ausführen → Ergebnis bewerten → Nächster Schritt oder Abschluss

Baustein 5 ist kein Add-on, sondern das, was einen Agenten unternehmenstauglich macht.

MCP IN 90 SEKUNDEN

Model Context Protocol: definierte Werkzeuge statt direktem Systemzugriff



Beispielhafte MCP Tools in der Demo

- `get_privileged_groups`
- `get_inactive_users`
- `get_password_policy_violations`
- `audit_admin_accounts`
- `get_user`
- `disable_user`
- `enable_user`

Read-only MCP · ohne Approval

Remediation MCP · Human Approval vor jeder Schreiboperation

EIN TOOL IST EIN VERTRAG

Was der Agent von einem MCP Tool sieht – und was nicht

Tool-Definition (vereinfacht)

```
name:         get_user
description:  Liest Status und Flags eines
              AD-Benutzerkontos (read-only)
input:        sAMAccountName (string)
output:       enabled, lastLogon,
              passwordNeverExpires,
              memberOf[]
server:       ca-ad-mcp-demo
account:      svc-mcp-read
```

Der Agent sieht

- ✓ Name und Beschreibung des Tools
- ✓ Erwartete Eingaben und Rückgabefelder
- ✓ Strukturierte Ergebnisse als Daten

Der Agent sieht nicht

- ✗ Passwörter, Zertifikate, Verbindungsdaten
- ✗ Den Domain Controller oder LDAP direkt
- ✗ Nicht angebotene Tools – z. B. delete_user

Was nicht als Tool existiert, kann der Agent nicht tun – egal, was im Prompt steht.

DIE PLATTFORM-BAUSTEINE

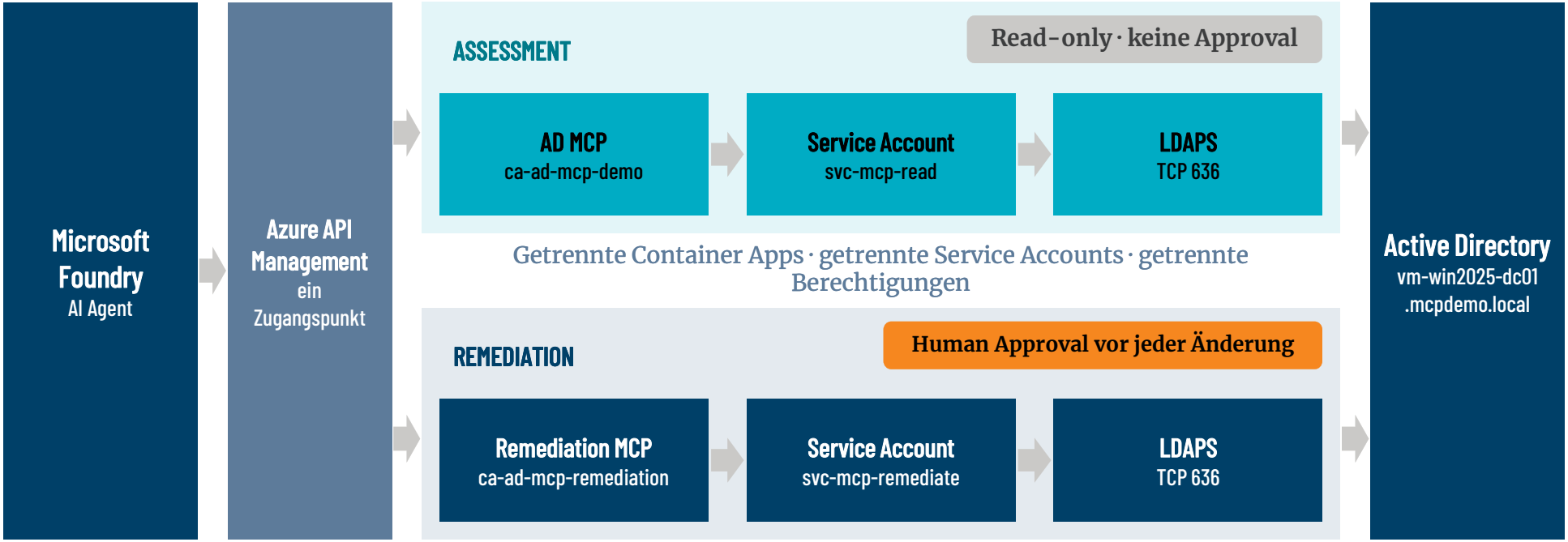
Microsoft Foundry, Azure API Management, Container Apps, LDAPS – was wofür

Microsoft Foundry Agent-Plattform	Azure API Management Kontrollierter Zugang	Azure Container Apps Laufzeit der MCP-Server	LDAPS Sichere Verbindung zu AD
● Hostet den Agenten mit Modell und Instruktionen	● Ein Zugangspunkt für alle MCP-Aufrufe	● Zwei getrennte Container: Read-only und Remediation	● Verschlüsselter LDAP über TCP 636
● Bindet MCP-Server als Tools ein	● Authentifizierung, Policies, Rate Limits	● Eigener Service Account je Container	● Nur vom Container-Netz zum Domain Controller
● Steuert Human Approval für sensible Tools	● Vollständiges Logging für Audit	● Skalierbar, isoliert, versionierbar	● Kein Klartext-LDAP, keine Passwörter im Transit

Zusammen ergibt das eine Kette, in der jedes Glied eine Kontrollfunktion hat – kein Baustein vertraut blind dem anderen.

DEMO-ARCHITEKTUR

Zwei technisch getrennte Pfade: Assessment (Read-only) und Remediation (Human Approval)



Read-only Account: besitzt keine administrativen Rechte.

Remediation Account: ausschließlich gezielt delegierte Rechte für die vorgesehenen Aktionen.

SECURITY BY DESIGN

Read-only versus Remediation, Least Privilege und Human Approval

AI Agent ≠ Domain Admin

Least Privilege

Nur die Rechte, die wirklich nötig sind

Read/Write Separation

Zwei MCP-Server, zwei Container Apps

Separate Service Accounts

svc-mcp-read und svc-mcp-remediate

LDAPS

Verschlüsselt zum Domain Controller (TCP 636)

API Management

Ein Zugangspunkt mit Auth und Logging

Credentials nicht im Prompt

Secrets bleiben in der Plattform

Human Approval

Manuelle Freigabe vor jeder Änderung

Unabhängige Verifikation

Read-only-Pfad prüft das Ergebnis

Für Entscheider

Governance und Kontrolle bleiben erhalten – der Agent handelt nur innerhalb definierter Leitplanken.

Für Administratoren

Technische Berechtigungen begrenzen, was der Agent tatsächlich tun kann – nicht der Prompt.

HUMAN APPROVAL IM DETAIL

Wie aus einem Vorschlag eine kontrollierte Änderung wird

1	2	3	4	5	6
Vorschlag	**Tool-Aufruf**	**Approval Gate**	**Entscheidung**	**Ausführung**	**Verifikation**
Remediation-Plan mit Begründung und betroffenem Objekt	disable_user über den Remediation MCP – noch nicht ausgeführt	Foundry stoppt und zeigt dem Menschen Aktion, Ziel und Kontext	Freigeben oder ablehnen – nachvollziehbar protokolliert	svc-mcp-remediate führt genau diese eine Aktion aus	Unabhängig über den Read-only-Pfad: Enabled = false

Für Entscheider

Jede Änderung hat einen menschlichen Entscheider und einen Audit-Eintrag – revisionssicher.

Für Administratoren

Das Gate sitzt in der Plattform, nicht im Prompt – der Agent kann es nicht umgehen.

Ablehnen ist jederzeit möglich – dann passiert im Active Directory schlicht nichts.

WAS KANN DER AGENT UNTERSUCHEN?

AD-Security-Tools des Read-only MCP und typische Findings

Tools des Read-only MCP

`get_privileged_groups`
Mitglieder privilegierter Gruppen

`get_inactive_users`
Konten ohne Anmeldung seit längerer Zeit

`get_password_policy_violations`
Verstöße gegen Passwortrichtlinien

`audit_admin_accounts`
Detailprüfung administrativer Konten

`get_user`
Einzelkonto mit Status und Flags

Korrelation

Beispiel-Findings

Privilegierter Account: Passwort läuft nie ab

Service Account „svc-backup“: Passwort läuft nie ab — Live-Demo

Starke Konzentration administrativer Rollen

Potenziell stale privilegierte Accounts

Der Mehrwert: Der Agent kombiniert mehrere Abfragen zu einem Assessment Report – statt fünf einzelner Skripte.

SO LÄUFT DIE DEMO

Vom Assessment bis zum optionalen Rollback – in fünfzehn Schritten

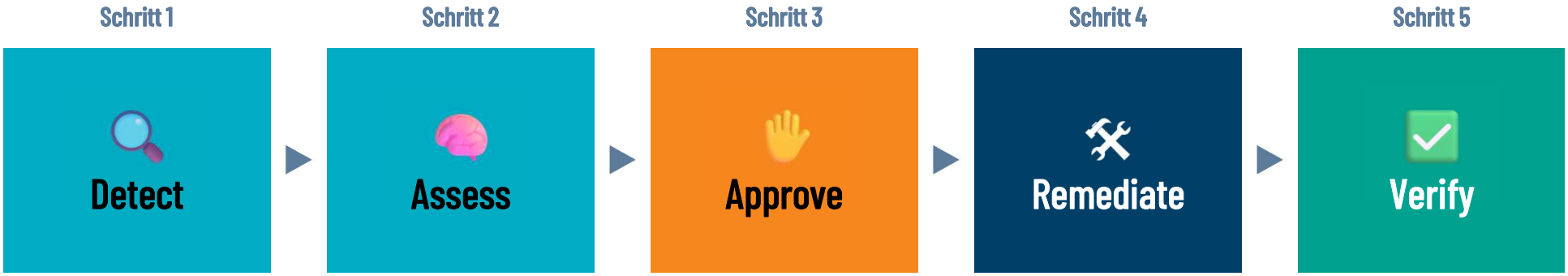
Detect	Assess	Approve	Remediate	Verify
1 Agent analysiert das AD	4 Findings mit Evidenz einordnen	7 Umsetzung anfordern	10 Freigabe erteilen	13 Read-only MCP prüft unabhängig
2 Nutzt mehrere MCP Tools selbst	5 Fokus: svc-backup	8 Remediation MCP ruft disable_user	11 svc-backup wird deaktiviert	14 Ergebnis: Enabled = false
3 Erstellt Assessment Report	6 Nur ein Plan – keine Änderung	9 Human Approval – bewusst stoppen	12 Protokolliert über API Management	15 Optional: Rollback mit enable_user

Worauf Sie achten sollten

Der Agent wählt die Tools selbst · Analyse und Änderung sind getrennte Schritte · Vor dem Approval passiert nichts · Die Verifikation läuft über einen anderen Pfad

LIVE DEMO

Vom Finding zum Fix



Ein AI Agent analysiert ein klassisches Active Directory, korreliert Findings und bereitet die Remediation vor – mit Human Approval.

GOVERNANCE-CHECKLISTE

Was vor dem ersten Agenten im Active Directory geklärt sein sollte

✓ **Scope definieren**

Welche Fragen darf der Agent stellen, welche Aktionen vorschlagen, welche ausführen?

✓ **Read und Write trennen**

Zwei MCP-Server, zwei Container, zwei Berechtigungssätze

✓ **Audit und Logging**

Jeder Tool-Aufruf über API Management protokolliert – auswertbar und revisionsfähig

✓ **Evidenzpflicht**

Kein Finding ohne Datenquelle – der Agent muss zeigen, woher er es weiß

✓ **Least Privilege technisch**

Eigene Service Accounts je Pfad, gezielte Delegation statt Admin-Gruppen

✓ **Approval-Regeln festlegen**

Welche Tools brauchen Freigabe, wer darf freigeben, wie wird eskaliert?

✓ **Rollback vorsehen**

Jede Remediation hat einen definierten Rückweg (z. B. enable_user)

✓ **Pilot statt Big Bang**

Mit Read-only in einer OU oder Testdomäne starten, dann erweitern

Diese acht Punkte sind in der Demo-Umgebung umgesetzt – sie sind der Unterschied zwischen Experiment und Betrieb.

CHANCEN UND GRENZEN

Nicht alles sollte autonom passieren

Chancen

- Ein Assessment-Durchlauf statt vieler einzelner Abfragen und Skripte
- Korrelation von Findings über Gruppen, Konten und Richtlinien hinweg
- Nachvollziehbare Remediation-Pläne mit Evidenz für jedes Finding
- Entlastung der Administratoren bei wiederkehrenden Prüfungen

Grenzen und Leitplanken

- Nicht alles sollte autonom durchgeführt werden – kritische Änderungen bleiben beim Menschen
- MCP-Tooling und Berechtigungen bestimmen, was tatsächlich möglich ist
- AI-Ausgaben müssen evidenzbasiert und prüfbar sein – kein Vertrauen ohne Daten
- Human-in-the-Loop bleibt insbesondere für kritische Änderungen relevant

Der Agent erweitert das Team – die Sicherheitsarchitektur entscheidet, was er tatsächlich darf.

VOM PILOTEN ZUM BETRIEB

Ein möglicher Weg in vier Stufen



Agent liest nur. Findings, Reports, Korrelation. Kein Schreibzugriff – null Risiko für den Betrieb.

Agent schlägt vor, Mensch gibt frei. Einfache, reversible Aktionen wie disable/enable.

Gruppen, Passwort-Rotation, Attribute – jeweils gezielt delegiert und mit Approval.

Anbindung an SIEM, ITSM und Ticketing – Findings werden zu Vorgängen, Approvals zu Workflows.

Jede Stufe erweitert, was der Agent darf – nie, was er umgehen kann.

TAKEAWAYS

Vier Aussagen, die hängen bleiben sollen

1	**MCP macht klassische Infrastruktur für AI Agents kontrolliert zugänglich.**
2	**Der Mehrwert entsteht durch Orchestrierung und Korrelation mehrerer Tools – nicht durch einzelne Abfragen.**
3	**Ein AI Agent braucht keine weitreichenden Admin-Rechte: Assessment und Remediation lassen sich mit Least Privilege technisch trennen.**
4	**Human Approval schafft den kontrollierten Übergang von Analyse zu Änderung – die Sicherheitsarchitektur entscheidet, was der Agent darf.**

Ihre Fragen?

Vom Finding zum Fix – Active Directory Security mit AI Agents und Model Context Protocol (MCP)

Gerne zeige ich die Demo-Umgebung, die MCP-Tools und das Berechtigungsmodell im Detail – im Anschluss oder per E-Mail.

Kontakt

Michael Herpers

Senior Manager
Technology Consulting – Microsoft
Protiviti GmbH · Düsseldorf

michael.herpers@protiviti.com
+49 151 52234253
www.protiviti.de

© 2026 Protiviti GmbH. Alle Rechte vorbehalten.

WAS HABEN WIR GERADE GESEHEN?

Vom natürlichsprachigen Auftrag bis zur unabhängigen Verifikation

Natural Language → Tool Orchestration → Evidence → Finding → Approval → Remediation → Verification

[SCREENSHOT: Foundry Security Assessment]

Der Agent orchestriert mehrere Tools und erstellt den Assessment Report mit evidenzbasierten Findings.

[SCREENSHOT: Human Approval vor disable_user]

Erst nach manueller Freigabe wird svc-backup deaktiviert – der Read-only MCP verifiziert anschließend: Enabled = false.